Évaluation des Risques et des Menaces - DocTrace

Référence : DOC-RISK-01 | **Version :** 1.0 | **Date :** Novembre 2026

---

1. Analyse des risques

1.1 Échelle d'évaluation (Grille 4×4)

Vraisemblance (V)

1. **Improbable (1) :** Nécessite des compétences d'exception et des conditions très complexes à réunir.
2. **Possible (2) :** Réalisable par un attaquant motivé disposant de ressources moyennes.
3. **Probable (3) :** Attaque connue, facile à réaliser par un utilisateur interne ou un attaquant ordinaire.
4. **Très probable (4) :** Vulnérabilité majeure exploitable automatiquement ou sans prérequis complexe.

Impact (I)

1. **Mineur (1) :** Perturbation négligeable sans fuite de secrets métier.
2. **Modéré (2) :** Atteinte locale à l'intégrité ou indisponibilité temporaire sans impact sur la confidentialité des documents.
3. **Majeur (3) :** Fuite d'un document confidentiel, contournement du marquage ou altération des traces.
4. **Critique (4) :** Fuite massive de documents strictly confidentiels, compromission totale des clés KEK/DEK ou falsification de preuves d'investigation.

Niveaux de risque bruts et résiduels (R = V * I)

- **Faible (1-3) :** Risque acceptable sous réserve de maintenance régulière.
- **Moyen (4-8) :** Risque nécessitant des mesures d'atténuation spécifiques.
- **Élevé (9-12) :** Risque inacceptable exigeant des contrôles de sécurité critiques immédiats.
- **Critique (15-16) :** Risque bloquant pour la mise en production.

---

2. Inventaire des actifs critiques et menaces associées

ID Actif	Actif concerné	Objectif principal (CIA)	Scénarios d'abus associés
A-01	Documents originaux (catalogue)	Confidentialité / Intégrité	MU-01, MU-02, MU-05
A-02	Copies distribuées et marques (PDF/PNG)	Intégrité / Non-répudiation	MU-04, MU-07
A-03	Secrets & Clés (KEK, stégano, HMAC, signatures)	Confidentialité / Intégrité	MU-05, MU-06
A-04	Identités, jetons OIDC et matrice ACL	Confidentialité / Intégrité	MU-01, MU-06, MU-08
A-05	Journaux d'audit chaînés & Rapports d'investigation	Intégrité / Disponibilité	MU-05, MU-07
A-06	Moteurs de traitement (PDFBox, ImageIO, ClamAV)	Disponibilité / Intégrité	MU-02, MU-03

---

3. Registre détaillé des risques et cartographie des menaces

Risque R-01 : Usurpation d'accès et contournement des droits ACL

- **Code Scénario d'Abus :** MU-01
- **Vecteur de menace :** Un employé malveillant (`READER`) modifie les identifiants de documents dans les requêtes API REST (`GET /api/documents/{id}/download`) pour accéder aux fichiers d'un tiers.
- **Évaluation initiale :** Vraisemblance = 3, Impact = 4 | **Risque Brut = Élevé (12)**
- **Mesures d'atténuation (SRS) :**
    - **SR-03 / SR-04 :** Contrôle d'accès strict au niveau objet (RBAC + ACL + Niveau d'habilitation) côté middleware sur chaque requête.

    - **Fail-closed :** Réponse 404 uniforme en cas d'absence de droit pour éviter toute fuite d'existence d'un document.
- **Évaluation résiduelle :** Vraisemblance = 1, Impact = 3 | **Risque Résiduel = Faible (3)**

Risque R-02 : Injection de fichiers malveillants ou d'exploits parseurs à l'upload

- **Code Scénario d'Abus :** MU-02
- **Vecteur de menace :** Un gestionnaire (`PUBLISHER`) compromis ou malveillant téléverse un fichier PDF/PNG piégé contenant du code exécutable ou exploitant une vulnérabilité de parsing (PDFBox / ImageIO).
- **Évaluation initiale :** Vraisemblance = 3, Impact = 4 | **Risque Brut = Élevé (12)**
- **Mesures d'atténuation (SRS) :**
    - **SR-06 :** Validation stricte des Magic Bytes, taille maximale (≤ 50 Mo) et analyse antivirus obligatoire via ClamAV avant intégration au catalogue.
    - **SR-07 :** Neutralisation du PDF (suppression des scripts JS, actions d'ouverture et pièces jointes) et restriction des dimensions d'images.
- **Évaluation résiduelle :** Vraisemblance = 1, Impact = 3 | **Risque Résiduel = Faible (3)**

Risque R-03 : Déni de service applicatif par épuisement des ressources de marquage

- **Code Scénario d'Abus :** MU-03
- **Vecteur de menace :** Un utilisateur lance de multiples demandes simultanées de téléchargement/marquage PDF et PNG lourds pour saturer le middleware et causer un Crash OOM (*Out Of Memory*).
- **Évaluation initiale :** Vraisemblance = 3, Impact = 3 | **Risque Brut = Élevé (9)**
- **Mesures d'atténuation (SRS) :**
    - **SR-23 :** Quotas stricts par utilisateur et dégradation élégante via une file d'attente à capacité bornée (Jakarta Concurrency).
    - **SR-07 / S-04 :** Plafonnements stricts de mémoire (1024 Mio par worker), d'exécution (120 s) et d'images (40 Mpx).
- **Évaluation résiduelle :** Vraisemblance = 1, Impact = 2 | **Risque Résiduel = Faible (2)**

Risque R-04 : Altération des marques ou livraison d'une copie non traçable

- **Code Scénario d'Abus :** MU-04
- **Vecteur de menace :** Un attaquant tente de contourner le processus de marquage pour obtenir un PDF propre sans marquage visible/discret ou stéganographie.
- **Évaluation initiale :** Vraisemblance = 2, Impact = 4 | **Risque Brut = Élevé (8)**

- **Mesures d'atténuation (SRS) :**
    - **D-01 (Porte de contrôle obligatoire) / Fail-closed :** En cas d'échec du service de marquage ou d'extraction de contrôle, la transaction s'interrompt et aucune copie n'est servie.
    - **SR-12 / SR-13 :** Marquage multi-page redondant et stéganographie AES-256-GCM LSB dans les PNG éligibles.
- **Évaluation résiduelle :** Vraisemblance = 1, Impact = 3 | **Risque Résiduel = Faible (3)**

Risque R-05 : Falsification des journaux d'audit ou corruption du stockage

- **Code Scénario d'Abus :** MU-05
- **Vecteur de menace :** Un administrateur ou un attaquant ayant compromis la base de données altère le journal d'audit pour effacer les traces d'un téléchargement illicite.
- **Évaluation initiale :** Vraisemblance = 2, Impact = 4 | **Risque Brut = Élevé (8)**
- **Mesures d'atténuation (SRS) :**
    - **SR-18 :** Journal d'audit chaîné cryptographiquement (`hashPrecedent` $\rightarrow$ `hashCourant` SHA-256). Toute modification directe en BD rompt la chaîne et déclenche une alerte.
    - **SR-16 :** Signatures HMAC-SHA256 ou Ed25519 isolées sur chaque enregistrement de distribution.
    - **SR-03 :** Aucun endpoint d'API de modification/suppression n'est exposed.
- **Évaluation résiduelle :** Vraisemblance = 1, Impact = 2 | **Risque Résiduel = Faible (2)**

Risque R-06 : Replay de jeton OIDC ou vol de session sur le poste client

- **Code Scénario d'Abus :** MU-06 / MU-08
- **Vecteur de menace :** Interception d'un jeton d'accès OAuth2/OIDC ou récupération du jeton dans le cache du navigateur sur un poste partagé.
- **Évaluation initiale :** Vraisemblance = 3, Impact = 3 | **Risque Brut = Élevé (9)**
- **Mesures d'atténuation (SRS) :**
    - **SR-01 / SR-02 :** PKCE S256 sur flux Authorization Code; interdiction stricte de stocker les jetons dans `localStorage`, `sessionStorage` ou `IndexedDB`.
    - **SR-21 :** Service Worker PWA configuré pour mettre en cache uniquement la coque applicative (`no-store` sur toutes les API et téléchargements).
- **Évaluation résiduelle :** Vraisemblance = 1, Impact = 2 | **Risque Résiduel = Faible (2)**

Risque R-07 : Falsification d'une marque et fausse accusation lors d'une fuite

- **Code Scénario d'Abus :** MU-07

- **Vecteur de menace :** Un utilisateur divulgue un document et forge artificiellement la marque stéganographique ou le watermark pour faire accuser un autre collègue.
- **Évaluation initiale :** Vraisemblance = 2, Impact = 4 | **Risque Brut = Élevé (8)**
- **Mesures d'atténuation (SRS) :**
    - **SR-13 / SR-16 :** La charge stéganographique et les preuves de distribution sont signées/chiffrées en AES-256-GCM et HMAC-SHA256 avec une clé secrète serveur.
    - **SR-17 :** Qualification prudente de l'investigation (Seul un tag cryptographique valide donne une confiance EXACTE ou PROBABLE; aucune accusation sans preuve authentifiée).
- **Évaluation résiduelle :** Vraisemblance = 1, Impact = 2 | **Risque Résiduel = Faible (2)**

---

4. Matrice de synthèse des risques (Avant / Après Mitigation)

Matrice Brute (Sans mesures SRE)

Vraisemblance \ Impact	1 (Mineur)	2 (Modéré)	3 (Majeur)	4 (Critique)
4 (Très probable)				
3 (Probable)		R-03	R-06	R-01, R-02
2 (Possible)			R-04	R-05, R-07
1 (Improbable)				

Matrice Résiduelle (Après SRS)

Vraisemblance \ Impact	1 (Mineur)	2 (Modéré)	3 (Majeur)	4 (Critique)
4 (Très probable)				
3 (Probable)				
2 (Possible)				
1 (Improbable)		R-03, R-05, R-06, R-07	R-01, R-02, R-04	

---

5. Déclarations d'acceptation des risques résiduels

Les risques résiduels suivants sont formellement identifiés et **acceptés par la conception du système (à améliorer dans le futur)** :

1. **Ressaisie manuelle et prise de photo de l'écran :** Une fois le document affiché ou téléchargé, DocTrace ne peut empêcher physiquement la capture par un appareil photo externe. Le marquage visible/discret dissuade et réduit ce risque mais ne le neutralise pas totalement.
2. **Altération destructrice extrême (Massive Cropping / Re-compression JPEG lourde) :** Si un utilisateur applique un traitement d'image destructeur extrême, la stéganographie LSB peut être détruite. Dans ce cas, la méthode d'investigation bascule sur l'empreinte SHA-256 et le watermark PDF discret redondant, ou conclut prudemment par un statut `AUCUNE` conformément à SR-17.